

CS 405 – Secure Coding

8-2 Journal: Portfolio Reflection

Malgorzata Debska

Southern New Hampshire University

Dr. Yi Wang

April 21, 2025

Creating strong and secure applications starts with using a secure coding standard from the very beginning. One of the biggest takeaways from this course is that you can't leave security at the end of a project, it must be built into every stage of development. Guidelines from trusted sources like OWASP and NIST help developers avoid common security issues like SQL injection, cross-site scripting, or unsafe data handling. When teams follow these standards from the start, they're more likely to catch and fix problems early, which saves time, money, and stress down the road. As we learned from *Secure Coding: Principles and Practices*, waiting until the final testing phase to think about security often leads to rushed fixes or overlooked vulnerabilities.

Alongside secure coding, understanding risk is also key. Not every security threat is equally dangerous, so it's important to evaluate which ones pose the greatest risk and figure out which ones are worth addressing right away. This course highlighted how risk assessments help prioritize threats based on how likely they are to happen and how much damage they could cause. Referencing the NIST Risk Management Framework, we learned that a cost-benefit approach helps organizations make smart decisions about how to manage these risks—balancing the cost of prevention against the potential cost of a breach.

Another major topic we covered is the “No one is safe” mindset, better known as the zero trust model. This approach assumes that every user, device, and application could be a threat until proven otherwise. That means verifying everything before granting access, even if someone is inside the network. According to NIST SP 800-207, zero trust involves continuous monitoring, giving users only the access they absolutely need, and breaking the system into smaller, secure pieces (a concept called micro-segmentation). With more people working remotely and using cloud services, this approach is more important than ever.

Lastly, putting strong security policies in place and making sure people follow them is critical to keeping systems secure. These policies lay out the rules for things like password strength, data access, and device use. But they also need to be practical, up to date, and clearly explained to everyone in the organization. As discussed in Information Security Policies, Procedures, and Standards, even the best policy won't work unless people understand it and know why it matters. That's why training and regular updates are just as important as the policies themselves.

In the end, all these elements secure coding, smart risk management, the zero trust model, and clear security policies work together to create a stronger and safer system. This course made it clear that security isn't something you can just check off a list, it's an ongoing effort that requires planning, awareness, and teamwork.

References:

National Institute of Standards and Technology. (2020). *Zero trust architecture (NIST Special Publication 800-207)*. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

Open Web Application Security Project (OWASP). (n.d.). *OWASP secure coding practices – Quick reference guide*. <https://owasp.org>